

已验证安全报告

扫描 ID: 0b0bbc0e-4fa8-4a1b-a05c-9200704fb25d

目标地址: <http://127.0.0.1:8765/>

生成时间: 2026-06-24T13:05:19+08:00

报告版本: v2.1

执行摘要

已验证漏洞: 39; 验证记录: 42; 待验证线索: 9; 完成步骤: 14 / 14; 产物数量: 9

已验证漏洞摘要

1. Confirmed authenticated object access bypass: username

严重级别: 高危; 漏洞类型: 权限绕过 / IDOR

位置: http://127.0.0.1:8765/vul/overpermission/op1/op1_mem.php?username=lili&submit=submit

关键证据: Strategy: authenticated_object_replay

Parameter: username

Attacker identity: lily

Victim object value: lili

Victim URL: http://127.0.0.1:8765/vul/overpermission/op1/op1_mem.php?username=lili&submit=submit

attacker_own_object: status=200, length=33820,

sensitive_markers=role,token,permission,logout, denied=False

attacker_victim_object: status=200, length=3382

...

修复建议: Bind object access to the authenticated subject and enforce object-level authorization for every profile/account lookup.

2. Confirmed authenticated privileged route bypass

严重级别: 高危; 漏洞类型: 权限绕过 / IDOR

位置: http://127.0.0.1:8765/vul/overpermission/op2/op2_admin_edit.php

关键证据: Strategy: authenticated_privileged_route_replay

Identity: pikachu

Privileged URL: http://127.0.0.1:8765/vul/overpermission/op2/op2_admin_edit.php

identity_landing_page: status=200, length=34720,

sensitive_markers=role,token,permission,logout, denied=False

privileged_route: status=200, length=34085,

sensitive_markers=role,token,permission,admin,logout, denied

...

修复建议: Apply server-side role checks on every privileged route, not only on login routing or menu rendering.

3. Exposed Git repository metadata/source inventory

严重级别: 高危; 漏洞类型: 备份 / 源码 / 元数据泄露

位置: <http://127.0.0.1:8765/.git/>

关键证据: [category=exposure][consumers=orchestrator,sql,js,poc]

evidence_kind=git_repository_metadata; Accessible Git metadata members:

.git/config:HTTP 200:git_config:preview=[core] repositoryformatversion = 0 filemode = true
bare = false logallrefupdates = true ignorecase = true [remote "origin"] url =
git@github.com:8023/pikachu.git | .git/HEAD:HTTP 200:git_head:pr

...

修复建议: Remove `.git` metadata from the web root and treat repository structure, commit
refs, and source inventory as disclosed.

4. Verified hard-coded sensitive information in JavaScript

严重级别: 高危; 漏洞类型: 前端敏感信息泄露

位置: <http://127.0.0.1:8765/assets/js/jquery-1.11.3.min.js>

关键证据: rule_id=plaintext-password; line=704; match_count=1;

sample=masked(plaintext-password:len=2;sample=**); remediation=Remove

browser-shipped secrets; use server-issued short-lived tokens and rotate leaked material.

修复建议: Remove hardcoded credentials from source and rotate the exposed accounts.

5. Verified hard-coded sensitive information in JavaScript

严重级别: 高危; 漏洞类型: 前端敏感信息泄露

位置: <http://127.0.0.1:8765/assets/js/jquery-2.1.4.min.js>

关键证据: rule_id=plaintext-password; line=679; match_count=1;

sample=masked(plaintext-password:len=2;sample=**); remediation=Remove

browser-shipped secrets; use server-issued short-lived tokens and rotate leaked material.

修复建议: Remove hardcoded credentials from source and rotate the exposed accounts.

6. SQL 注入证据候选参数: id

严重级别: 高危; 漏洞类型: SQL 注入

位置: [http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Entrypoint fetch: HTTP 200, title=Get the pikachu

Page: http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=92

Parameter: id

Source: linked-query

Reason: Linked page contains a query parameter that can be reviewed.

Controlled verification:

- Method: GET

- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=1

- Baseline body

...

修复建议: Use parameterized queries or prepared statements, validate parameter types
server-side, and suppress database error details in HTTP responses.

7. SQL 注入证据候选参数: id

严重级别: 高危; 漏洞类型: SQL 注入

位置: [http://127.0.0.1:8765/vul/sqli/sqli_id.php?id=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_id.php?id=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Entrypoint fetch: HTTP 200, title=Get the pikachu

Page: http://127.0.0.1:8765/vul/sqli/sqli_id.php

Parameter: id

Source: form:POST

Reason: Form input name matches common SQL injection candidate parameters.

Controlled verification:

- Method: POST

- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_id.php
- Baseline body: submit=

...

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

8. SQL 注入证据候选参数: name

严重级别: 高危; 漏洞类型: SQL 注入

位置: [http://127.0.0.1:8765/vul/sqli/sqli_search.php?name=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_search.php?name=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Entrypoint fetch: HTTP 200, title=Get the pikachu

Page: http://127.0.0.1:8765/vul/sqli/sqli_search.php

Parameter: name

Source: form:GET

Reason: Form input name matches common SQL injection candidate parameters.

Controlled verification:

- Method: GET

- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C

...

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

9. SQL 注入证据候选参数: name

严重级别: 高危; 漏洞类型: SQL 注入

位置: [http://127.0.0.1:8765/vul/sqli/sqli_str.php?name=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_str.php?name=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Entrypoint fetch: HTTP 200, title=Get the pikachu

Page: http://127.0.0.1:8765/vul/sqli/sqli_str.php

Parameter: name

Source: form:GET

Reason: Form input name matches common SQL injection candidate parameters.

Controlled verification:

- Method: GET

- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_str.php?submit=%E6%9F%A5%E8%AF

...

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

10. SQL 注入证据候选参数: name

严重级别: 高危; 漏洞类型: SQL 注入

位置: [http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php?name=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php?name=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Entrypoint fetch: HTTP 200, title=Get the pikachu

Page: http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php

Parameter: name

Source: form:POST

Reason: Form input name matches common SQL injection candidate parameters.

Controlled verification:

- Method: POST

- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php

- Baseline

...

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

11. SQL 注入证据候选参数: name

严重级别: 高危; 漏洞类型: SQL 注入

位置: [http://127.0.0.1:8765/vul/sqli/sqli_x.php?name=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_x.php?name=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Entrypoint fetch: HTTP 200, title=Get the pikachu

Page: http://127.0.0.1:8765/vul/sqli/sqli_x.php

Parameter: name

Source: form:GET

Reason: Form input name matches common SQL injection candidate parameters.

Controlled verification:

- Method: GET

- Baseline URL:

http://127.0.0.1:8765/vul/sqli/sqli_x.php?submit=%E6%9F%A5%E8%AF%A2&

...

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

12. Confirmed SSRF loopback fetch via url

严重级别: 高危; 漏洞类型: SSRF

位置: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http%3A%2F%2F127.0.0.1%2F

关键证据: Page: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php

Method: GET

Parameter: url

Baseline URL:

http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http://127.0.0.1/vul/ssrf/ssrf_info/info1.php

Probe URL: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http%3A%2F%2F127.0.0.1%2F

Probe value: <http://127.0.0.1/>

Baseline status: 200

Probe status: 200

Direct status: 0

...

修复建议: Allowlist outbound schemes and hosts, block loopback/link-local/internal ranges, and isolate server-side fetchers.

13. Confirmed SSRF loopback fetch via file

严重级别: 高危; 漏洞类型: SSRF

位置: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http%3A%2F%2F127.0.0.1%2F

关键证据: Page: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php

Method: GET

Parameter: file

Baseline URL:

http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http://127.0.0.1/vul/ssrf/ssrf_info/info2.php

Probe URL: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http%3A%2F%2F127.0.0.1%2F

Probe value: <http://127.0.0.1/>

Baseline status: 200

Probe status: 200

Direct status: 0

...

修复建议: Allowlist outbound schemes and hosts, block loopback/link-local/internal ranges, and isolate server-side fetchers.

14. Weak/default credential accepted for admin

严重级别: 高危; 漏洞类型: weak_password

位置: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php

关键证据: Strategy: bounded_login_submission

Login page: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php

Action: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php

Method: POST

Username field: username

Password field: password

Accepted username: admin

Accepted password: 1****6

Final URL: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_he

...

修复建议: Disable default credentials, require password rotation, and add rate limiting/lockout on login endpoints.

15. Weak/default credential accepted for admin

严重级别: 高危; 漏洞类型: weak_password

位置: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php

关键证据: Strategy: bounded_login_submission

Login page: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php

Action: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php

Method: POST

Username field: username

Password field: password

Accepted username: admin

Accepted password: 1****6

Final URL: http://127.0.0.1:8765/vul/xss/xsspost/xss_reflected_post.php

Status: 200

A

...

修复建议: Disable default credentials, require password rotation, and add rate limiting/lockout on login endpoints.

16. XSS 证据候选参数: message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/sqli/sqli_del.php?message=\[controlled-test\]](http://127.0.0.1:8765/vul/sqli/sqli_del.php?message=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/sqli/sqli_del.php

Method: POST

Parameter: message

Context: html_body

Confirmed strategies: html_body

Basis: html_body: payload reached html_body context; status=200

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

17. XSS 证据候选参数: name

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/sqli/sqli_search.php?name=[controlled-test]

关键证据：Target: http://127.0.0.1:8765/

Page: http://127.0.0.1:8765/vul/sqli/sqli_search.php

Method: GET

Parameter: name

Context: html_body

Confirmed strategies: attribute_breakout

Basis: attribute_breakout: payload reached html_body context; status=200

修复建议：Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

18. XSS 证据候选参数：name

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/sqli/sqli_str.php?name=[controlled-test]

关键证据：Target: http://127.0.0.1:8765/

Page: http://127.0.0.1:8765/vul/sqli/sqli_str.php

Method: GET

Parameter: name

Context: html_body

Confirmed strategies: attribute_breakout

Basis: attribute_breakout: payload reached html_body context; status=200

修复建议：Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

19. XSS 证据候选参数：name

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/sqli/sqli_x.php?name=[controlled-test]

关键证据：Target: http://127.0.0.1:8765/

Page: http://127.0.0.1:8765/vul/sqli/sqli_x.php

Method: GET

Parameter: name

Context: html_body

Confirmed strategies: attribute_breakout

Basis: attribute_breakout: payload reached html_body context; status=200

修复建议：Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

20. XSS 证据候选参数：message

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/xss/xss_01.php?message=[controlled-test]

关键证据：Target: http://127.0.0.1:8765/

Page: http://127.0.0.1:8765/vul/xss/xss_01.php

Method: GET

Parameter: message

Context: html_body

Confirmed strategies: html_body

Basis: html_body: payload reached html_body context; status=200

修复建议：Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

21. Browser-confirmed XSS candidate on message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: http://127.0.0.1:8765/vul/xss/xss_01.php?submit=submit&message=%3Csvg+onload%3Dalert%281%29%3E

关键证据: Payload reflected into browser DOM context: html_body

修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

22. XSS 证据候选参数: message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/xss/xss_02.php?message=\[controlled-test\]](http://127.0.0.1:8765/vul/xss/xss_02.php?message=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_02.php

Method: GET

Parameter: message

Context: href

Confirmed strategies: html_body

Basis: html_body: payload reached href context; status=200

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

23. Browser-confirmed XSS candidate on message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: http://127.0.0.1:8765/vul/xss/xss_02.php?submit=submit&message=%27%3Balert%281%29%2F%2F

关键证据: Payload reflected into browser DOM context: js_string

修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

24. XSS 证据候选参数: message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/xss/xss_03.php?message=\[controlled-test\]](http://127.0.0.1:8765/vul/xss/xss_03.php?message=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_03.php

Method: GET

Parameter: message

Context: href

Confirmed strategies: html_body

Basis: html_body: payload reached href context; status=200

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

25. XSS 证据候选参数: message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/xss/xss_04.php?message=\[controlled-test\]](http://127.0.0.1:8765/vul/xss/xss_04.php?message=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_04.php

Method: GET

Parameter: message

Context: script

Confirmed strategies: html_body

Basis: html_body: payload reached script context; status=200

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

26. Browser-confirmed XSS candidate on message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: http://127.0.0.1:8765/vul/xss/xss_04.php?submit=submit&message=%3Csvg+onload%3Dalert%281%29%3E

关键证据: Payload reflected into browser DOM context: html_body

修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

27. XSS 证据候选参数: text

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/xss/xss_dom.php?text=\[controlled-test\]](http://127.0.0.1:8765/vul/xss/xss_dom.php?text=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_dom.php

Method: GET

Parameter: text

Context: dom_source_sink

Confirmed strategies: html_body

Basis: html_body: payload reached dom_source_sink context; status=200;
source_sink=getElementById("text").value->innerHTML

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

28. XSS 证据候选参数: text

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/xss/xss_dom_x.php?text=\[controlled-test\]](http://127.0.0.1:8765/vul/xss/xss_dom_x.php?text=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_dom_x.php

Method: GET

Parameter: text

Context: dom_source_sink

Confirmed strategies: html_body

Basis: html_body: payload reached dom_source_sink context; status=200;
source_sink=window.location.search->innerHTML

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

29. XSS 证据候选参数: message

严重级别: 高危; 漏洞类型: 跨站脚本 (XSS)

位置: [http://127.0.0.1:8765/vul/xss/xss_reflected_get.php?message=\[controlled-test\]](http://127.0.0.1:8765/vul/xss/xss_reflected_get.php?message=[controlled-test])

关键证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_reflected_get.php

Method: GET

Parameter: message

Context: html_body

Confirmed strategies: html_body

Basis: html_body: payload reached html_body context; status=200

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

30. Browser-confirmed XSS candidate on message

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/xss/xss_reflected_get.php?submit=submit&message=%3Csvg+xmlns=xmlns%3Dalert%281%29%3E

关键证据：Payload reflected into browser DOM context: html_body

修复建议：Apply contextual output encoding and reject active markup in user-controlled fields.

31. XSS 证据候选参数：message

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/xss/xss_stored.php?message=[controlled-test]

关键证据：Target: http://127.0.0.1:8765/

Page: http://127.0.0.1:8765/vul/xss/xss_stored.php

Method: POST

Parameter: message

Context: html_body

Confirmed strategies: html_body

Basis: html_body: payload reached html_body context; status=200

修复建议：Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

32. Browser-confirmed XSS candidate on message

严重级别：高危；漏洞类型：跨站脚本（XSS）

位置：http://127.0.0.1:8765/vul/xss/xss_stored.php?submit=submit&message=%3Csvg+xmlns=xmlns%3Dalert%281%29%3E

关键证据：Payload reflected into browser DOM context: no_space

修复建议：Apply contextual output encoding and reject active markup in user-controlled fields.

33. Exposed macOS directory metadata

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/.DS_Store

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc] .DS_Store -> HTTP 200; evidence_kind=ds_store; entries=assets, Dockerfile, footer.php, header.php, inc, index.php, install.php, LICENSE, pkxss, README.md, test, vul, wiki, ShowTabView, ContainerShowSidebar, WindowBounds, ShowSidebar, 1173, 737, myz; preview=entries=assets, Dockerfile, footer.php, header

...

修复建议：Remove `DS\_Store` files from public directories and prevent development metadata from being deployed.

34. Exposed source or deployment metadata

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/.gitattributes

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc] .gitattributes -> HTTP 200; evidence_kind=source_metadata; preview=# Auto detect text files and perform LF normalization * text=auto

修复建议：Remove source and deployment metadata from public web roots.

35. Exposed source or deployment metadata

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/Dockerfile

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc] Dockerfile -> HTTP 200; evidence_kind=deployment_metadata; preview=FROM mattrayner/lamp:latest-2004-php7 LABEL maintainer="8023 - i@8023.moe" LABEL description="pikachu on php7 with expect @230613" COPY ./app/ RUN export http_

修复建议：Remove source and deployment metadata from public web roots.

36. Metadata-inferred backup or source artifact

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/assets/css/bootstrap.min.css.bak

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc]

assets/css/bootstrap.min.css.bak -> HTTP 200; content_type=application/x-trash;

evidence_kind=editor_backup; preview=/*! * Bootstrap v3.3.6 (http://getbootstrap.com) *

Copyright 2011-2015 Twitter, Inc. * Licensed under MIT

(https://github.com/twbs/bootstrap/blob/master/LICENSE

修复建议：Remove metadata-discovered backup or source artifacts from public web roots.

37. Metadata-inferred macOS directory metadata

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/test/.DS_Store

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc] test/.DS_Store -> HTTP

200; evidence_kind=ds_store; entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt;

preview=entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt

修复建议：Remove `DS\_Store` files from public directories and prevent development metadata from being deployed.

38. Metadata-inferred macOS directory metadata

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/vul/.DS_Store

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc] vul/.DS_Store -> HTTP

200; evidence_kind=ds_store; entries=eforce, burteforce, csrf, dir, fileinclude, infoleak,

overpermission, rce, sql, ssrf, unsafedownload, unsafeupload, unserialization, urlredirect, xss,

xxe, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar;

preview=entries=eforce, bur

...

修复建议：Remove `DS\_Store` files from public directories and prevent development metadata from being deployed.

39. Metadata-inferred macOS directory metadata

严重级别：中危；漏洞类型：备份 / 源码 / 元数据泄露

位置：http://127.0.0.1:8765/wiki/.DS_Store

关键证据：[category=exposure][consumers=orchestrator,sql,js,poc] wiki/.DS_Store -> HTTP

200; evidence_kind=ds_store; entries=image, ShowTabView_, ContainerShowSidebar,

WindowBounds, ShowSidebar, 1540, 297, 819, 528, myz, elg1Scomp, emoDDblob,

emodDblob, eph1Scomp, evSrnlong; preview=entries=image, ShowTabView_,

ContainerShowSidebar, WindowBounds, ShowSidebar, 1540, 29

...

修复建议：Remove `DS\_Store` files from public directories and prevent development metadata from being deployed.

待验证线索摘要

1. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/ace-extra.min.js>

证据摘要: Sources=localStorage; DOM sinks=innerHTML; DOM sink evidence=c.innerHTML@L1:C2899 `c.innerHTML=b` | c.innerHTML@L1:C2899 `c.innerHTML=b`; remediation=Replace innerHTML/outerHTML/document.write with textContent or DOM-safe rendering helpers.

2. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/jquery-1.11.3.min.js>

证据摘要: Sources=location.hash, location.href; DOM sinks=innerHTML, outerHTML; DOM sink evidence=innerHTML@L2:C9981 `o.appendChild(a).innerHTML="<a id="+u+"></a><select id="+u+"-fj' msallowcapture="><option selected="></option></select>"` | a.innerHTML@L2:C22157 `a.innerHTML="<a href='#"></a>"` | a.innerHTML@L2:C22376 `a.innerHTML="<input/>"`; remediation=Repla
...

3. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/jquery-2.1.4.min.js>

证据摘要: Sources=location.hash, location.href; DOM sinks=innerHTML; DOM sink evidence=innerHTML@L2:C9731 `o.appendChild(a).innerHTML="<a id="+u+"></a><select id="+u+"-fj' msallowcapture="><option selected="></option></select>"` | a.innerHTML@L2:C21907 `a.innerHTML="<a href='#"></a>"` | a.innerHTML@L2:C22126 `a.innerHTML="<input/>"`; remediation=Replace innerHTM
...

4. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/#inline-script-20>

证据摘要: Execution sinks=function; ast.eval_calls=0; ast.new_function_calls=0; remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

5. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/bootstrap.min.js>

证据摘要: Execution sinks=function, setInterval, setTimeout; ast.eval_calls=0; ast.new_function_calls=0; remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

6. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/excanvas.min.js>

证据摘要: Execution sinks=function; ast.eval_calls=0; ast.new_function_calls=0; remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

7. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/html5shiv.min.js>

证据摘要: Execution sinks=Function, function; ast.eval_calls=0; ast.new_function_calls=0;
remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

8. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/jquery-ui.custom.min.js>

证据摘要: Execution sinks=function, setTimeout; ast.eval_calls=0; ast.new_function_calls=0;
remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

9. JavaScript 辅助评估

位置: <http://127.0.0.1:8765/assets/js/respond.min.js>

证据摘要: Execution sinks=function, setTimeout; ast.eval_calls=0; ast.new_function_calls=0;
remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

附录 A：已验证漏洞详细证据

1. Confirmed authenticated object access bypass: username

影响: Strategy: authenticated_object_replay

完整证据: Strategy: authenticated_object_replay

Parameter: username

Attacker identity: lily

Victim object value: lili

Victim URL: http://127.0.0.1:8765/vul/overpermission/op1/op1_mem.php?username=lili&submit=submit

attacker_own_object: status=200, length=33820, sensitive_markers=role,token,permission,logout,

denied=False

attacker_victim_object: status=200, length=33820, sensitive_markers=role,token,permission,logout,

denied=False

复现步骤:

- Replay the protected request to http://127.0.0.1:8765/vul/overpermission/op1/op1_mem.php?username=lily&submit=submit across multiple identities.
- Mutate identifier parameter username across object boundaries.
- Compare status codes and sensitive response markers across identities.

修复建议: Bind object access to the authenticated subject and enforce object-level authorization for every profile/account lookup.

2. Confirmed authenticated privileged route bypass

影响: Strategy: authenticated_privileged_route_replay

完整证据: Strategy: authenticated_privileged_route_replay

Identity: pikachu

Privileged URL: http://127.0.0.1:8765/vul/overpermission/op2/op2_admin_edit.php

identity_landing_page: status=200, length=34720, sensitive_markers=role,token,permission,logout,

denied=False

privileged_route: status=200, length=34085, sensitive_markers=role,token,permission,admin,logout,

denied=False

privileged_markers=admin,edit,delete,account

复现步骤:

- Replay the protected request to http://127.0.0.1:8765/vul/overpermission/op2/op2_admin_edit.php across multiple identities.
- Compare status codes and sensitive response markers across identities.

修复建议: Apply server-side role checks on every privileged route, not only on login routing or menu rendering.

3. Exposed Git repository metadata/source inventory

影响: [category=exposure][consumers=orchestrator,sql,js,poc]

evidence_kind=git_repository_metadata; Accessible Git metadata members:

.git/config:HTTP 200:git_config:preview=[core] repositoryformatversion = 0 filemode = true bare = false logallrefupdates = true ignorecase = true [remote "origin"] url = git@github.com:8023/pikachu.git | .git/HEAD:HTTP 200:git_head:preview=ref: refs/heads/master | .git/index:HTTP 200:git_index:entries=.DS_Store, .gitattributes, Dockerfile, LICENSE, README.md, assets/css/ace-ie.min.css, assets/css/ace-part2.min.css, assets/css/ace-rtl.min.css, assets/css/ace-skins.min.css, assets/css/ace.min.css, assets/css/bootstrap-colorpicker.min.css, assets/css/bootstrap-datepicker

...

完整证据: [category=exposure][consumers=orchestrator,sql,js,poc]

evidence_kind=git_repository_metadata; Accessible Git metadata members: .git/config:HTTP 200:git_config:preview=[core] repositoryformatversion = 0 filemode = true bare = false logallrefupdates = true ignorecase = true [remote "origin"] url = git@github.com:8023/pikachu.git | .git/HEAD:HTTP 200:git_head:preview=ref: refs/heads/master | .git/index:HTTP 200:git_index:entries=.DS_Store, .gitattributes, Dockerfile, LICENSE, README.md, assets/css/ace-ie.min.css, assets/css/ace-part2.min.css,

assets/css/ace-rtl.min.css, assets/css/ace-skins.min.css, assets/css/ace.min.css,
assets/css/bootstrap-colorpicker.min.css, assets/css/bootstrap-datepicker3.min.css,
assets/css/bootstrap-datetimepicker.min.css, assets/css/bootstrap-duallistbox.min.css,
assets/css/bootstrap-editable.min.css, assets/css/bootstrap-multiselect.min.css,
assets/css/bootstrap-timepicker.min.css, assets/css/bootstrap.min.css, assets/css/bootstrap.min.css.bak,
assets/css/chosen.min.css, assets/css/colorbox.min.css, assets/css/daterangepicker.min.css,
assets/css/dropzone.min.css, assets/css/font-awesome.min.css, assets/css/fonts.googleapis.com.css,
assets/css/fullcalendar.m

...
复现步骤:

- GET http://127.0.0.1:8765/.git/.
- Confirm the exposed artifact path .git/.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove `.git` metadata from the web root and treat repository structure, commit refs, and source inventory as disclosed.

4. Verified hard-coded sensitive information in JavaScript

影响: rule_id=plaintext-password; line=704; match_count=1;
sample=masked(plaintext-password:len=2;sample=**); remediation=Remove
browser-shipped secrets; use server-issued short-lived tokens and rotate leaked material.

完整证据: rule_id=plaintext-password; line=704; match_count=1;
sample=masked(plaintext-password:len=2;sample=**); remediation=Remove browser-shipped secrets;
use server-issued short-lived tokens and rotate leaked material.

复现步骤:

- GET http://127.0.0.1:8765/assets/js/jquery-1.11.3.min.js.
- Review JavaScript line 704 for the masked sensitive assignment.
- Confirm the matched secret rule plaintext-password.

修复建议: Remove hardcoded credentials from source and rotate the exposed accounts.

5. Verified hard-coded sensitive information in JavaScript

影响: rule_id=plaintext-password; line=679; match_count=1;
sample=masked(plaintext-password:len=2;sample=**); remediation=Remove
browser-shipped secrets; use server-issued short-lived tokens and rotate leaked material.

完整证据: rule_id=plaintext-password; line=679; match_count=1;
sample=masked(plaintext-password:len=2;sample=**); remediation=Remove browser-shipped secrets;
use server-issued short-lived tokens and rotate leaked material.

复现步骤:

- GET http://127.0.0.1:8765/assets/js/jquery-2.1.4.min.js.
- Review JavaScript line 679 for the masked sensitive assignment.
- Confirm the matched secret rule plaintext-password.

修复建议: Remove hardcoded credentials from source and rotate the exposed accounts.

6. SQL 注入证据候选参数: id

影响: quote_error: single quote response contains SQL/database error markers;
response_delta: quote probe differs from baseline by 4507 bytes; union_basic: basic
union-select probe; baseline_delta=4492, false_delta=4492, true_delta=4492;
comment_obfuscated: keyword spacing with inline SQL comments; baseline_delta=1690,
false_delta=1690, true_delta=1690; case_mixed: mixed-case keyword variant;
baseline_delta=1690, false_delta=1690, true_delta=1690; space_comment: space replaced
with SQL comments; baseline_delta=1690, false_delta=1690, true_delta=1690; plus_space:
space replaced with plus separators; baseline_delta=4501, false_delta=4501,
true_delta=4501; tab_space: space replaced with tab character

...

完整证据: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=92
Parameter: id
Source: linked-query
Reason: Linked page contains a query parameter that can be reviewed.
Controlled verification:
- Method: GET
- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=1
- Baseline body: N/A
- Baseline elapsed ms: 11
- Quote probe HTTP status: 200
- Baseline length: 35128
- Quote length: 30621
- Boolean true length: 35128
- Boolean false length: 35128
- Time-delay length: 35128
- Time-delay elapsed ms: 6
- Time-delay delta ms: 0
- Union-style length: 30636
- Comment-bypass length: 33438
- Confirmed strategies: between_variant, case_mixed, comment_obfuscated, dash_comment_suffix, hash_comment_suffix, like_variant, mysql_version_comment, newline_space, operator_symbol, paren_wrapped, plus_space, quote_error, response_delta, space_comment, tab_space, union_basic
- Strategy lengths: between_variant=33438, boolean_false=35128, boolean_true=35128, case_mixed=33438, comment_obfuscated=33438, dash_comment_suffix=33438, hash_comment_suffix=33438, like_variant=33438, mysql_version_comment=33438, newline_space=33438, ope

...
复现步骤:

- Send the baseline GET request to http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=1.
- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=92 with controlled parameter id.
- Apply the confirmed strategy set: between_variant, case_mixed, comment_obfuscated, dash_comment_suffix.

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

7. SQL 注入证据候选参数: id

影响: quote_error: single quote response contains SQL/database error markers;
response_delta: quote probe differs from baseline by 4507 bytes; union_basic: basic union-select probe; baseline_delta=4492, false_delta=4492, true_delta=4492;
comment_obfuscated: keyword spacing with inline SQL comments; baseline_delta=1690, false_delta=1690, true_delta=1690; case_mixed: mixed-case keyword variant; baseline_delta=1690, false_delta=1690, true_delta=1690; space_comment: space replaced with SQL comments; baseline_delta=1690, false_delta=1690, true_delta=1690; plus_space: space replaced with plus separators; baseline_delta=4501, false_delta=4501, true_delta=4501; tab_space: space replaced with tab character

...

完整证据: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_id.php
Parameter: id
Source: form:POST
Reason: Form input name matches common SQL injection candidate parameters.
Controlled verification:
- Method: POST
- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_id.php
- Baseline body: submit=%E6%9F%A5%E8%AF%A2&id=1
- Baseline elapsed ms: 23
- Quote probe HTTP status: 200
- Baseline length: 33669

- Quote length: 30621
- Boolean true length: 33669
- Boolean false length: 33640
- Time-delay length: 33640
- Time-delay elapsed ms: 2006
- Time-delay delta ms: 1983
- Union-style length: 33721
- Comment-bypass length: 34095
- Confirmed strategies: comment_obfuscated, plus_space, quote_error, response_delta, time_delay
- Strategy lengths: between_variant=33669, boolean_false=33640, boolean_true=33669, case_mixed=33669, comment_obfuscated=34095, dash_comment_suffix=33669, hash_comment_suffix=33669, like_variant=33669, mysql_version_comment=33669, newline_space=33669, operator_symbol=33669, paren_wrapped=33669, plus_space=30627, quote_error=30621, space_comment=33669, tab_space=33669
- Decision basis: quote_error: single quote r

...

复现步骤:

- Send the baseline GET request to http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=1.
- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=92 with controlled parameter id.
- Apply the confirmed strategy set: between_variant, case_mixed, comment_obfuscated, dash_comment_suffix.

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

8. SQL 注入证据候选参数: name

影响: quote_error: single quote response contains SQL/database error markers; response_delta: quote probe differs from baseline by 2637 bytes; plus_space: space replaced with plus separators; baseline_delta=2626, false_delta=2626, true_delta=2626; paren_wrapped: boolean expression wrapped in parentheses; baseline_delta=2639, false_delta=2639, true_delta=2639; between_variant: truth condition expressed with BETWEEN; baseline_delta=2638, false_delta=2638, true_delta=2638; like_variant: truth condition expressed with LIKE; baseline_delta=2637, false_delta=2637, true_delta=2637; encoding_escape_bypass: percent-encoded multibyte quote probe for charset/escaping edge cases; baseline_delta=2637, false_de

...

完整证据: Target: <http://127.0.0.1:8765/>
 Entrypoint fetch: HTTP 200, title=Get the pikachu
 Page: http://127.0.0.1:8765/vul/sqli/sqli_search.php
 Parameter: name
 Source: form:GET
 Reason: Form input name matches common SQL injection candidate parameters.
 Controlled verification:
 - Method: GET
 - Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=1
 - Baseline body: N/A
 - Baseline elapsed ms: 8
 - Quote probe HTTP status: 200
 - Baseline length: 33259
 - Quote length: 30622
 - Boolean true length: 33259
 - Boolean false length: 33259
 - Time-delay length: 33259
 - Time-delay elapsed ms: 6
 - Time-delay delta ms: 0
 - Union-style length: 30535
 - Comment-bypass length: 33259
 - Confirmed strategies: between_variant, encoding_escape_bypass, like_variant, paren_wrapped, plus_space, quote_error, response_delta
 - Strategy lengths: between_variant=30621, boolean_false=33259, boolean_true=33259,

case_mixed=33259, comment_obfuscated=33259, dash_comment_suffix=33259,
encoding_escape_bypass=30622, hash_comment_suffix=33259, like_variant=30622,
mysql_version_comment=33259, newline_space=33259, operator_symbol=33259,
paren_wrapped=30620, plus_space=30633, quote_error=30622, space

...
复现步骤:

- Send the baseline GET request to
`http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=1.`
 - Replay GET against `http://127.0.0.1:8765/vul/sqli/sqli_search.php` with controlled parameter name.
 - Apply the confirmed strategy set: `between_variant`, `encoding_escape_bypass`, `like_variant`, `paren_wrapped`.
- 修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

9. SQL 注入证据候选参数: name

影响: `quote_error`: single quote response contains SQL/database error markers;
`response_delta`: quote probe differs from baseline by 2637 bytes; `plus_space`: space replaced with plus separators; `baseline_delta`=2626, `false_delta`=2626, `true_delta`=2626;
`paren_wrapped`: boolean expression wrapped in parentheses; `baseline_delta`=2639, `false_delta`=2639, `true_delta`=2639; `between_variant`: truth condition expressed with BETWEEN; `baseline_delta`=2638, `false_delta`=2638, `true_delta`=2638; `like_variant`: truth condition expressed with LIKE; `baseline_delta`=2637, `false_delta`=2637, `true_delta`=2637;
`encoding_escape_bypass`: percent-encoded multibyte quote probe for charset/escaping edge cases; `baseline_delta`=2637, `false_delta`

...

完整证据: Target: `http://127.0.0.1:8765/`
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: `http://127.0.0.1:8765/vul/sqli/sqli_str.php`
Parameter: name
Source: form:GET
Reason: Form input name matches common SQL injection candidate parameters.
Controlled verification:
- Method: GET
- Baseline URL: `http://127.0.0.1:8765/vul/sqli/sqli_str.php?submit=%E6%9F%A5%E8%AF%A2&name=1`
- Baseline body: N/A
- Baseline elapsed ms: 7
- Quote probe HTTP status: 200
- Baseline length: 33251
- Quote length: 30624
- Boolean true length: 33251
- Boolean false length: 33251
- Time-delay length: 33251
- Time-delay elapsed ms: 7
- Time-delay delta ms: 0
- Union-style length: 33262
- Comment-bypass length: 33701
- Confirmed strategies: `between_variant`, `comment_obfuscated`, `encoding_escape_bypass`, `like_variant`, `paren_wrapped`, `plus_space`, `quote_error`, `response_delta`
- Strategy lengths: `between_variant`=30624, `boolean_false`=33251, `boolean_true`=33251, `case_mixed`=33251, `comment_obfuscated`=33701, `dash_comment_suffix`=33251, `encoding_escape_bypass`=30624, `hash_comment_suffix`=33251, `like_variant`=30624, `mysql_version_comment`=33251, `newline_space`=33251, `operator_symbol`=33251, `paren_wrapped`=30620, `plus_space`=30631, `quote_error`

...
复现步骤:

- Send the baseline GET request to
`http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=1.`
- Replay GET against `http://127.0.0.1:8765/vul/sqli/sqli_search.php` with controlled parameter name.
- Apply the confirmed strategy set: `between_variant`, `encoding_escape_bypass`, `like_variant`,

paren wrapped.

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

10. SQL 注入证据候选参数: name

影响: quote_error: single quote response contains SQL/database error markers; response_delta: quote probe differs from baseline by 2637 bytes; plus_space: space replaced with plus separators; baseline_delta=2626, false_delta=2626, true_delta=2626; paren_wrapped: boolean expression wrapped in parentheses; baseline_delta=2639, false_delta=2639, true_delta=2639; between_variant: truth condition expressed with BETWEEN; baseline_delta=2638, false_delta=2638, true_delta=2638; like_variant: truth condition expressed with LIKE; baseline_delta=2637, false_delta=2637, true_delta=2637; encoding_escape_bypass: percent-encoded multibyte quote probe for charset/escaping edge cases; baseline_delta=2637, false_de

...

完整证据: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php
Parameter: name
Source: form:POST
Reason: Form input name matches common SQL injection candidate parameters.
Controlled verification:
- Method: POST
- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php
- Baseline body: submit=%E6%9F%A5%E8%AF%A2&name=1
- Baseline elapsed ms: 8
- Quote probe HTTP status: 200
- Baseline length: 33284
- Quote length: 33284
- Boolean true length: 33284
- Boolean false length: 33284
- Time-delay length: 33284
- Time-delay elapsed ms: 6
- Time-delay delta ms: 0
- Union-style length: 33284
- Comment-bypass length: 33284
- Confirmed strategies: encoding_escape_bypass
- Strategy lengths: between_variant=33284, boolean_false=33284, boolean_true=33284, case_mixed=33284, comment_obfuscated=33284, dash_comment_suffix=33284, encoding_escape_bypass=34696, hash_comment_suffix=33284, like_variant=33284, mysql_version_comment=33284, newline_space=33284, operator_symbol=33284, paren_wrapped=33284, plus_space=33284, quote_error=33284, space_comment=33284
Decision basis: encoding_escape_bypass: percent-encoded multibyte quot

复现步骤:

- Send the baseline GET request to http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=1.
- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_search.php with controlled parameter name.
- Apply the confirmed strategy set: between_variant, encoding_escape_bypass, like_variant, paren_wrapped.

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

11. SQL 注入证据候选参数: name

影响: quote_error: single quote response contains SQL/database error markers; response_delta: quote probe differs from baseline by 2637 bytes; plus_space: space replaced with plus separators; baseline_delta=2626, false_delta=2626, true_delta=2626;

paren_wrapped: boolean expression wrapped in parentheses; baseline_delta=2639, false_delta=2639, true_delta=2639; between_variant: truth condition expressed with BETWEEN; baseline_delta=2638, false_delta=2638, true_delta=2638; like_variant: truth condition expressed with LIKE; baseline_delta=2637, false_delta=2637, true_delta=2637; encoding_escape_bypass: percent-encoded multibyte quote probe for charset/escaping edge cases; baseline_delta=2637, false_de

...

完整证据: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_x.php
Parameter: name
Source: form:GET
Reason: Form input name matches common SQL injection candidate parameters.
Controlled verification:
- Method: GET
- Baseline URL: http://127.0.0.1:8765/vul/sqli/sqli_x.php?submit=%E6%9F%A5%E8%AF%A2&name=1
- Baseline body: N/A
- Baseline elapsed ms: 6
- Quote probe HTTP status: 200
- Baseline length: 33258
- Quote length: 30625
- Boolean true length: 33708
- Boolean false length: 33708
- Time-delay length: 33708
- Time-delay elapsed ms: 7
- Time-delay delta ms: 1
- Union-style length: 30642
- Comment-bypass length: 33258
- Confirmed strategies: between_variant, encoding_escape_bypass, like_variant, paren_wrapped, plus_space, quote_error, response_delta, union_basic
- Strategy lengths: between_variant=30625, boolean_false=33708, boolean_true=33708, case_mixed=33708, comment_obfuscated=33258, dash_comment_suffix=33708, encoding_escape_bypass=30625, hash_comment_suffix=33708, like_variant=30625, mysql_version_comment=33708, newline_space=33708, operator_symbol=33708, paren_wrapped=30620, plus_space=30632, quote_error=30625, sp

...

复现步骤:

- Send the baseline GET request to http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=1.
- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_search.php with controlled parameter name.
- Apply the confirmed strategy set: between_variant, encoding_escape_bypass, like_variant, paren_wrapped.

修复建议: Use parameterized queries or prepared statements, validate parameter types server-side, and suppress database error details in HTTP responses.

12. Confirmed SSRF loopback fetch via url

影响: URL-bearing query parameter discovered from same-origin route inventory.

完整证据: Page: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php
Method: GET
Parameter: url
Baseline URL: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http://127.0.0.1/vul/ssrf/ssrf_info/info1.php
Probe URL: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http%3A%2F%2F127.0.0.1%2F
Probe value: http://127.0.0.1/
Baseline status: 200
Probe status: 200
Direct status: 0
Basis: loopback_response_delta
Delta length: 33784
Direct overlap: 0.0

复现步骤:

- Replay the SSRF entry page http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php and control parameter url.
- Replay the recorded request
http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http://127.0.0.1/vul/ssrf/ssrf_info/info1.php.
- Use the controlled internal/OOB probe value
http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http%3A%2F%2F127.0.0.1%2F.
- Confirm the matched internal markers or callback proof.

修复建议: Allowlist outbound schemes and hosts, block loopback/link-local/internal ranges, and isolate server-side fetchers.

13. Confirmed SSRF loopback fetch via file

影响: URL-bearing query parameter discovered from same-origin route inventory.

完整证据: Page: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php
Method: GET
Parameter: file
Baseline URL: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http://127.0.0.1/vul/ssrf/ssrf_info/info2.php
Probe URL: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http%3A%2F%2F127.0.0.1%2F
Probe value: <http://127.0.0.1/>
Baseline status: 200
Probe status: 200
Direct status: 0
Basis: loopback_response_delta
Delta length: 33757
Direct overlap: 0.0

复现步骤:

- Replay the SSRF entry page http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php and control parameter file.
- Replay the recorded request
http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http://127.0.0.1/vul/ssrf/ssrf_info/info2.php.
- Use the controlled internal/OOB probe value
http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http%3A%2F%2F127.0.0.1%2F.
- Confirm the matched internal markers or callback proof.

修复建议: Allowlist outbound schemes and hosts, block loopback/link-local/internal ranges, and isolate server-side fetchers.

14. Weak/default credential accepted for admin

影响: Strategy: bounded_login_submission

完整证据: Strategy: bounded_login_submission
Login page: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php
Action: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php
Method: POST
Username field: username
Password field: password
Accepted username: admin
Accepted password: 1****6
Final URL: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header.php
Status: 200
Authenticated markers: 欢迎, logout

复现步骤:

- Open the login page http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php.
- Submit the POST login form to
http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php.
- Use username=admin with the recorded masked weak/default password candidate.
- Confirm authenticated response markers such as logout/profile/dashboard or a post-login URL.

修复建议: Disable default credentials, require password rotation, and add rate limiting/lockout on login endpoints.

15. Weak/default credential accepted for admin

影响: Strategy: bounded_login_submission

完整证据: Strategy: bounded_login_submission

Login page: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php

Action: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php

Method: POST

Username field: username

Password field: password

Accepted username: admin

Accepted password: 1****6

Final URL: http://127.0.0.1:8765/vul/xss/xsspost/xss_reflected_post.php

Status: 200

Authenticated markers: 欢迎, logout

复现步骤:

- Open the login page http://127.0.0.1:8765/vul/xss/xsspost/post_login.php.
- Submit the POST login form to http://127.0.0.1:8765/vul/xss/xsspost/post_login.php.
- Use username=admin with the recorded masked weak/default password candidate.
- Confirm authenticated response markers such as logout/profile/dashboard or a post-login URL.

修复建议: Disable default credentials, require password rotation, and add rate limiting/lockout on login endpoints.

16. XSS 证据候选参数: message

影响: html_body: payload reached html_body context; status=200

完整证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/sqli/sqli_del.php

Method: POST

Parameter: message

Context: html_body

Confirmed strategies: html_body

Basis: html_body: payload reached html_body context; status=200

复现步骤:

- Replay POST against http://127.0.0.1:8765/vul/sqli/sqli_del.php with controlled parameter message.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

17. XSS 证据候选参数: name

影响: attribute_breakout: payload reached html_body context; status=200

完整证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/sqli/sqli_search.php

Method: GET

Parameter: name

Context: html_body

Confirmed strategies: attribute_breakout

Basis: attribute_breakout: payload reached html_body context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_search.php with controlled parameter name.
- Open the controlled URL http://127.0.0.1:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=%27%3E%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_2debb5ff00.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

18. XSS 证据候选参数: name

影响: attribute_breakout: payload reached html_body context; status=200

完整证据: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/sqli/sqli_str.php
Method: GET
Parameter: name
Context: html_body
Confirmed strategies: attribute_breakout
Basis: attribute_breakout: payload reached html_body context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_str.php with controlled parameter name.
- Open the controlled URL http://127.0.0.1:8765/vul/sqli/sqli_str.php?submit=%E6%9F%A5%E8%AF%A2&name=%27%3E%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_bb1ae3dc57.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

19. XSS 证据候选参数: name

影响: attribute_breakout: payload reached html_body context; status=200

完整证据: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/sqli/sqli_x.php
Method: GET
Parameter: name
Context: html_body
Confirmed strategies: attribute_breakout
Basis: attribute_breakout: payload reached html_body context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/sqli/sqli_x.php with controlled parameter name.
- Open the controlled URL http://127.0.0.1:8765/vul/sqli/sqli_x.php?submit=%E6%9F%A5%E8%AF%A2&name=%27%3E%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_f1c8fde935.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

20. XSS 证据候选参数: message

影响: html body: payload reached html_body context; status=200

完整证据: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_01.php
Method: GET
Parameter: message
Context: html_body
Confirmed strategies: html_body
Basis: html_body: payload reached html_body context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/xss/xss_01.php with controlled parameter message.
- Open the controlled URL http://127.0.0.1:8765/vul/xss/xss_01.php?submit=submit&message=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_26cb19f616.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

21. Browser-confirmed XSS candidate on message

影响: Attacker-controlled markup reaches a browser-rendered execution context.

完整证据: Payload reflected into browser DOM context: html_body

复现步骤:

- Open http://127.0.0.1:8765/vul/xss/xss_01.php
 - Set message to `<svg onload=alert(1)>`
 - Load the mutated URL in a browser and inspect DOM/screenshot artifact.
- 修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

22. XSS 证据候选参数: message

影响: html_body: payload reached href context; status=200

完整证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_02.php

Method: GET

Parameter: message

Context: href

Confirmed strategies: html_body

Basis: html_body: payload reached href context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/xss/xss_02.php with controlled parameter message.
- Open the controlled URL http://127.0.0.1:8765/vul/xss/xss_02.php?submit=submit&message=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_d5993c6119.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

23. Browser-confirmed XSS candidate on message

影响: Attacker-controlled markup reaches a browser-rendered execution context.

完整证据: Payload reflected into browser DOM context: js_string

复现步骤:

- Open http://127.0.0.1:8765/vul/xss/xss_02.php
- Set message to `'alert(1)//`
- Load the mutated URL in a browser and inspect DOM/screenshot artifact.

修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

24. XSS 证据候选参数: message

影响: html_body: payload reached href context; status=200

完整证据: Target: <http://127.0.0.1:8765/>

Page: http://127.0.0.1:8765/vul/xss/xss_03.php

Method: GET

Parameter: message

Context: href

Confirmed strategies: html_body

Basis: html_body: payload reached href context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/xss/xss_03.php with controlled parameter message.
- Open the controlled URL http://127.0.0.1:8765/vul/xss/xss_03.php?submit=submit&message=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_5b30a60c92.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

25. XSS 证据候选参数: message

影响: html_body: payload reached script context; status=200

完整证据: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_04.php
Method: GET
Parameter: message
Context: script
Confirmed strategies: html_body
Basis: html_body: payload reached script context; status=200

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/xss/xss_04.php with controlled parameter message.
- Open the controlled URL http://127.0.0.1:8765/vul/xss/xss_04.php?submit=submit&message=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_c9008cdfc9.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

26. Browser-confirmed XSS candidate on message

影响: Attacker-controlled markup reaches a browser-rendered execution context.

完整证据: Payload reflected into browser DOM context: html_body

复现步骤:

- Open http://127.0.0.1:8765/vul/xss/xss_04.php
 - Set message to <svg onload=alert(1)>
 - Load the mutated URL in a browser and inspect DOM/screenshot artifact.
- 修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

27. XSS 证据候选参数: text

影响: html_body: payload reached dom_source_sink context; status=200;
source_sink=getElementById("text").value->innerHTML

完整证据: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_dom.php
Method: GET
Parameter: text
Context: dom_source_sink
Confirmed strategies: html_body
Basis: html_body: payload reached dom_source_sink context; status=200;
source_sink=getElementById("text").value->innerHTML

复现步骤:

- Replay GET against http://127.0.0.1:8765/vul/xss/xss_dom.php with controlled parameter text.
- Open the controlled URL http://127.0.0.1:8765/vul/xss/xss_dom.php?submit=submit&text=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_00f8e892c5.

修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

28. XSS 证据候选参数: text

影响: html_body: payload reached dom_source_sink context; status=200;
source_sink=window.location.search->innerHTML

完整证据: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_dom_x.php
Method: GET
Parameter: text
Context: dom_source_sink
Confirmed strategies: html_body
Basis: html_body: payload reached dom_source_sink context; status=200;
source_sink=window.location.search->innerHTML

复现步骤:

- Replay GET against `http://127.0.0.1:8765/vul/xss/xss_dom_x.php` with controlled parameter text.
- Open the controlled URL `http://127.0.0.1:8765/vul/xss/xss_dom_x.php?submit=submit&text=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_7abe79a6c8`.
修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

29. XSS 证据候选参数: message

影响: `html_body: payload reached html_body context; status=200`

完整证据: Target: `http://127.0.0.1:8765/`
Page: `http://127.0.0.1:8765/vul/xss/xss_reflected_get.php`
Method: GET
Parameter: message
Context: `html_body`
Confirmed strategies: `html_body`
Basis: `html_body: payload reached html_body context; status=200`

复现步骤:

- Replay GET against `http://127.0.0.1:8765/vul/xss/xss_reflected_get.php` with controlled parameter message.
- Open the controlled URL `http://127.0.0.1:8765/vul/xss/xss_reflected_get.php?submit=submit&message=%3Csvg%2Fonload%3Dalert%281%29%3EXSS_MARKER_1e1dc51265`.
修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

30. Browser-confirmed XSS candidate on message

影响: Attacker-controlled markup reaches a browser-rendered execution context.

完整证据: Payload reflected into browser DOM context: `html_body`

复现步骤:

- Open `http://127.0.0.1:8765/vul/xss/xss_reflected_get.php`
- Set message to `<svg onload=alert(1)>`
- Load the mutated URL in a browser and inspect DOM/screenshot artifact.
修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

31. XSS 证据候选参数: message

影响: `html_body: payload reached html_body context; status=200`

完整证据: Target: `http://127.0.0.1:8765/`
Page: `http://127.0.0.1:8765/vul/xss/xss_stored.php`
Method: POST
Parameter: message
Context: `html_body`
Confirmed strategies: `html_body`
Basis: `html_body: payload reached html_body context; status=200`

复现步骤:

- Replay POST against `http://127.0.0.1:8765/vul/xss/xss_stored.php` with controlled parameter message.
修复建议: Apply contextual output encoding, sanitize active markup, and avoid writing attacker-controlled values into executable browser contexts.

32. Browser-confirmed XSS candidate on message

影响: Attacker-controlled markup reaches a browser-rendered execution context.

完整证据: Payload reflected into browser DOM context: `no_space`

复现步骤:

- Open `http://127.0.0.1:8765/vul/xss/xss_stored.php`
 - Set message to `<svg/onload=alert(1)>`
 - Load the mutated URL in a browser and inspect DOM/screenshot artifact.
- 修复建议: Apply contextual output encoding and reject active markup in user-controlled fields.

33. Exposed macOS directory metadata

影响: `[category=exposure][consumers=orchestrator,sql,js,poc] .DS_Store -> HTTP 200;`
`evidence_kind=ds_store; entries=assets, Dockerfile, footer.php, header.php, inc, index.php, install.php, LICENSE, pkxss, README.md, test, vul, wiki, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1173, 737, myz;`
`preview=entries=assets, Dockerfile, footer.php, header.php, inc, index.php, install.php, LICENSE, pkxss, README.md, test, vul, wiki, ShowTabView_, ContainerShowSidebar,`
 完整证据: `[category=exposure][consumers=orchestrator,sql,js,poc] .DS_Store -> HTTP 200;`
`evidence_kind=ds_store; entries=assets, Dockerfile, footer.php, header.php, inc, index.php, install.php, LICENSE, pkxss, README.md, test, vul, wiki, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1173, 737, myz; preview=entries=assets, Dockerfile, footer.php, header.php, inc, index.php, install.php, LICENSE, pkxss, README.md, test, vul, wiki, ShowTabView_, ContainerShowSidebar,`

复现步骤:

- GET `http://127.0.0.1:8765/.DS_Store`.
- Confirm the exposed artifact path `.DS_Store`.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove `.DS_Store` files from public directories and prevent development metadata from being deployed.

34. Exposed source or deployment metadata

影响: `[category=exposure][consumers=orchestrator,sql,js,poc] .gitattributes -> HTTP 200;`
`evidence_kind=source_metadata; preview=# Auto detect text files and perform LF normalization * text=auto`
 完整证据: `[category=exposure][consumers=orchestrator,sql,js,poc] .gitattributes -> HTTP 200;`
`evidence_kind=source_metadata; preview=# Auto detect text files and perform LF normalization * text=auto`

复现步骤:

- GET `http://127.0.0.1:8765/.gitattributes`.
- Confirm the exposed artifact path `.gitattributes`.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove source and deployment metadata from public web roots.

35. Exposed source or deployment metadata

影响: `[category=exposure][consumers=orchestrator,sql,js,poc] Dockerfile -> HTTP 200;`
`evidence_kind=deployment_metadata; preview=FROM mattrayner/lamp:latest-2004-php7 LABEL maintainer="8023 - i@8023.moe" LABEL description="pikachu on php7 with expect @230613" COPY . /app/ RUN export http_`
 完整证据: `[category=exposure][consumers=orchestrator,sql,js,poc] Dockerfile -> HTTP 200;`
`evidence_kind=deployment_metadata; preview=FROM mattrayner/lamp:latest-2004-php7 LABEL maintainer="8023 - i@8023.moe" LABEL description="pikachu on php7 with expect @230613" COPY . /app/ RUN export http_`

复现步骤:

- GET `http://127.0.0.1:8765/Dockerfile`.
- Confirm the exposed artifact path `Dockerfile`.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove source and deployment metadata from public web roots.

36. Metadata-inferred backup or source artifact

影响: [category=exposure][consumers=orchestrator,sql,js,poc] assets/css/bootstrap.min.css.bak -> HTTP 200; content_type=application/x-trash; evidence_kind=editor_backup; preview=/*! * Bootstrap v3.3.6 (http://getbootstrap.com) * Copyright 2011-2015 Twitter, Inc. * Licensed under MIT (https://github.com/twbs/bootstrap/blob/master/LICENSE
完整证据: [category=exposure][consumers=orchestrator,sql,js,poc] assets/css/bootstrap.min.css.bak -> HTTP 200; content_type=application/x-trash; evidence_kind=editor_backup; preview=/*! * Bootstrap v3.3.6 (http://getbootstrap.com) * Copyright 2011-2015 Twitter, Inc. * Licensed under MIT (https://github.com/twbs/bootstrap/blob/master/LICENSE

复现步骤:

- GET http://127.0.0.1:8765/assets/css/bootstrap.min.css.bak.
- Confirm the exposed artifact path assets/css/bootstrap.min.css.bak.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove metadata-discovered backup or source artifacts from public web roots.

37. Metadata-inferred macOS directory metadata

影响: [category=exposure][consumers=orchestrator,sql,js,poc] test/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt; preview=entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt
完整证据: [category=exposure][consumers=orchestrator,sql,js,poc] test/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt; preview=entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt

复现步骤:

- GET http://127.0.0.1:8765/test/.DS_Store.
- Confirm the exposed artifact path test/.DS_Store.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove `DS\_Store` files from public directories and prevent development metadata from being deployed.

38. Metadata-inferred macOS directory metadata

影响: [category=exposure][consumers=orchestrator,sql,js,poc] vul/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=eforce, burteforce, csrf, dir, fileinclude, infoleak, overpermission, rce, sql, ssrf, unsafedownload, unsafeupload, unserilization, urlredirect, xss, xxe, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar; preview=entries=eforce, burteforce, csrf, dir, fileinclude, infoleak, overpermission, rce, sql, ssrf, unsafedownload, unsafeupload, unserilization, urlredirect, xss, x
完整证据: [category=exposure][consumers=orchestrator,sql,js,poc] vul/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=eforce, burteforce, csrf, dir, fileinclude, infoleak, overpermission, rce, sql, ssrf, unsafedownload, unsafeupload, unserilization, urlredirect, xss, xxe, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar; preview=entries=eforce, burteforce, csrf, dir, fileinclude, infoleak, overpermission, rce, sql, ssrf, unsafedownload, unsafeupload, unserilization, urlredirect, xss, x

复现步骤:

- GET http://127.0.0.1:8765/vul/.DS_Store.
- Confirm the exposed artifact path vul/.DS_Store.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove `DS\_Store` files from public directories and prevent development metadata from being deployed.

39. Metadata-inferred macOS directory metadata

影响: [category=exposure][consumers=orchestrator,sql.js,poc] wiki/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=image, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1540, 297, 819, 528, myz, elg1Scomp, emoDDblob, emodDblob, eph1Scomp, evSrnlorg; preview=entries=image, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1540, 297, 819, 528, myz, elg1Scomp, emoDDblob, emodDblob, eph1Scomp, evSrnlorg

完整证据: [category=exposure][consumers=orchestrator,sql.js,poc] wiki/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=image, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1540, 297, 819, 528, myz, elg1Scomp, emoDDblob, emodDblob, eph1Scomp, evSrnlorg; preview=entries=image, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1540, 297, 819, 528, myz, elg1Scomp, emoDDblob, emodDblob, eph1Scomp, evSrnlorg

复现步骤:

- GET http://127.0.0.1:8765/wiki/.DS_Store.
- Confirm the exposed artifact path wiki/.DS_Store.
- Confirm the passive exposure returned HTTP 200.
- Review the masked source/config evidence from the artifact.

修复建议: Remove `.DS\_Store` files from public directories and prevent development metadata from being deployed.

附录 B：验证记录

1. verify-265c436d39e2

验证方式：authenticated_idor_object_access

状态：已验证

证据摘录：Strategy: authenticated_object_replay

Parameter: username

Attacker identity: lily

Victim object value: lili

Victim URL: http://127.0.0.1:8765/vul/overpermission/op1/op1_mem.php?username=lili&submit=submit

attacker_own_object: status=200, le

2. verify-3659bf50ad03

验证方式：authenticated_privileged_route_replay

状态：已验证

证据摘录：Strategy: authenticated_privileged_route_replay

Identity: pikachu

Privileged URL: http://127.0.0.1:8765/vul/overpermission/op2/op2_admin_edit.php

identity_landing_page: status=200, length=34720, sensitive_markers=role,token,permission,logou

3. verify-45eec406336a

验证方式：backup_passive_exposure

状态：已验证

证据摘录：[category=exposure][consumers=orchestrator,sql,js,poc] test/.DS_Store -> HTTP 200;

evidence_kind=ds_store; entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt; preview=entries=nfo.tx, phpinfo.txt, ser.php, test.php, yijuhua.txt

4. verify-56ec434eb053

验证方式：backup_passive_exposure

状态：已验证

证据摘录：[category=exposure][consumers=orchestrator,sql,js,poc]

evidence_kind=git_repository_metadata; Accessible Git metadata members: .git/config:HTTP

200:git_config:preview=[core] repositoryformatversion = 0 filemode = true bare = false logallref

5. verify-a13742ef6ee5

验证方式：backup_passive_exposure

状态：已验证

证据摘录：[category=exposure][consumers=orchestrator,sql,js,poc] .DS_Store -> HTTP 200;

evidence_kind=ds_store; entries=assets, Dockerfile, footer.php, header.php, inc, index.php, install.php, LICENSE, pkxss, README.md, test, vul, wiki, ShowTabView_

6. verify-a6a509af3de1

验证方式：backup_passive_exposure

状态：已验证

证据摘录：[category=exposure][consumers=orchestrator,sql,js,poc] .gitattributes -> HTTP 200;

evidence_kind=source_metadata; preview=# Auto detect text files and perform LF normalization *
text=auto

7. verify-c1e6706ce8e6

验证方式：backup_passive_exposure

状态: 已验证

证据摘录: [category=exposure][consumers=orchestrator,sql.js,poc] assets/css/bootstrap.min.css.bak -> HTTP 200; content_type=application/x-trash; evidence_kind=editor_backup; preview=/*! * Bootstrap v3.3.6 (http://getbootstrap.com) * Copyright 2011-20

8. verify-f00143ff5094

验证方式: backup_passive_exposure

状态: 已验证

证据摘录: [category=exposure][consumers=orchestrator,sql.js,poc] Dockerfile -> HTTP 200; evidence_kind=deployment_metadata; preview=FROM matttrayner/lamp:latest-2004-php7 LABEL maintainer="8023 - i@8023.moe" LABEL description="pikachu on php7 with exp

9. verify-f07e00066f96

验证方式: backup_passive_exposure

状态: 已验证

证据摘录: [category=exposure][consumers=orchestrator,sql.js,poc] vul/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=eforce, burteforce, csrf, dir, fileinclude, infoleak, overpermission, rce, sqli, ssrf, unsafedownload, unsafeupload, unserializ

10. verify-f9753e084571

验证方式: backup_passive_exposure

状态: 已验证

证据摘录: [category=exposure][consumers=orchestrator,sql.js,poc] wiki/.DS_Store -> HTTP 200; evidence_kind=ds_store; entries=image, ShowTabView_, ContainerShowSidebar, WindowBounds, ShowSidebar, 1540, 297, 819, 528, myz, elg1Scomp, emoDDblob, emodDbI

11. verify-15b983eca51b

验证方式: 布尔差异验证

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_widebyte.php
Parameter: name
Source: form:POST
Reason: Form input name matches common SQL injection candidate paramet

12. verify-22d92fd04462

验证方式: 布尔差异验证

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_del.php?id=92
Parameter: id
Source: linked-query
Reason: Linked page contains a query parameter that can be reviewed.

13. verify-6ddc9e615fad

验证方式: 布尔差异验证

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_str.php

Parameter: name
Source: form:GET
Reason: Form input name matches common SQL injection candidate parameters.
C

14. verify-8d3f85b90ef1

验证方式: 布尔差异验证

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_id.php
Parameter: id
Source: form:POST
Reason: Form input name matches common SQL injection candidate parameters.
Con

15. verify-9bc7e09bc78d

验证方式: 布尔差异验证

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_search.php
Parameter: name
Source: form:GET
Reason: Form input name matches common SQL injection candidate parameters

16. verify-e66d77fa771b

验证方式: 布尔差异验证

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Entrypoint fetch: HTTP 200, title=Get the pikachu
Page: http://127.0.0.1:8765/vul/sqli/sqli_x.php
Parameter: name
Source: form:GET
Reason: Form input name matches common SQL injection candidate parameters.
Con

17. verify-216f2f618122

验证方式: bounded_login_submission

状态: 已验证

证据摘录: Strategy: bounded_login_submission
Login page: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php
Action: http://127.0.0.1:8765/vul/sqli/sqli_header/sqli_header_login.php
Method: POST
Username field: username
Password field: p

18. verify-68cdb0b76f52

验证方式: bounded_login_submission

状态: 已验证

证据摘录: Strategy: bounded_login_submission
Login page: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php
Action: http://127.0.0.1:8765/vul/xss/xsspost/post_login.php
Method: POST

Username field: username
Password field: password
Accepted usernam

19. verify-04765da6d510

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/sqli/sqli_str.php
Method: GET
Parameter: name
Context: html_body
Confirmed strategies: attribute_breakout
Basis: attribute_breakout: payload reached html_body context; status=20

20. verify-0bf6b74eaf0e

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Payload reflected into browser DOM context: js_string

21. verify-0daf50518e14

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_01.php
Method: GET
Parameter: message
Context: html_body
Confirmed strategies: html_body
Basis: html_body: payload reached html_body context; status=200

22. verify-305831fa19a4

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Payload reflected into browser DOM context: no_space

23. verify-34388d94f074

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_dom.php
Method: GET
Parameter: text
Context: dom_source_sink
Confirmed strategies: html_body
Basis: html_body: payload reached dom_source_sink context; status=200; sourc

24. verify-40396806990e

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Payload reflected into browser DOM context: html_body

25. verify-40fccf665462

验证方式：浏览器 DOM 执行上下文

状态：已验证

证据摘录： Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_dom_x.php
Method: GET
Parameter: text
Context: dom_source_sink
Confirmed strategies: html_body
Basis: html_body: payload reached dom_source_sink context; status=200; sou

26. verify-59716e20b5cc

验证方式：浏览器 DOM 执行上下文

状态：已验证

证据摘录： Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/sqli/sqli_search.php
Method: GET
Parameter: name
Context: html_body
Confirmed strategies: attribute_breakout
Basis: attribute_breakout: payload reached html_body context; status

27. verify-5efc37f6d451

验证方式：浏览器 DOM 执行上下文

状态：已验证

证据摘录： Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/sqli/sqli_del.php
Method: POST
Parameter: message
Context: html_body
Confirmed strategies: html_body
Basis: html_body: payload reached html_body context; status=200

28. verify-7393f373016c

验证方式：浏览器 DOM 执行上下文

状态：已验证

证据摘录： Payload reflected into browser DOM context: html_body

29. verify-9ab6f7e9b0fd

验证方式：浏览器 DOM 执行上下文

状态：已验证

证据摘录： Payload reflected into browser DOM context: html_body

30. verify-b034f9a7a2f9

验证方式：浏览器 DOM 执行上下文

状态：已验证

证据摘录： Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_stored.php
Method: POST
Parameter: message
Context: html_body

Confirmed strategies: html_body
Basis: html_body: payload reached html_body context; status=200

31. verify-e42ee424b6a8

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/sqli/sqli_x.php
Method: GET
Parameter: name
Context: html_body
Confirmed strategies: attribute_breakout
Basis: attribute_breakout: payload reached html_body context; status=200

32. verify-ff111dec5451

验证方式: 浏览器 DOM 执行上下文

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_reflected_get.php
Method: GET
Parameter: message
Context: html_body
Confirmed strategies: html_body
Basis: html_body: payload reached html_body context; status=200

33. verify-1ac690e0d332

验证方式: browser_href_context

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_03.php
Method: GET
Parameter: message
Context: href
Confirmed strategies: html_body
Basis: html_body: payload reached href context; status=200

34. verify-b281f10a70fd

验证方式: browser_href_context

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_02.php
Method: GET
Parameter: message
Context: href
Confirmed strategies: html_body
Basis: html_body: payload reached href context; status=200

35. verify-a3cdaa25c7c5

验证方式: browser_script_context

状态: 已验证

证据摘录: Target: http://127.0.0.1:8765/
Page: http://127.0.0.1:8765/vul/xss/xss_04.php
Method: GET
Parameter: message

Context: script
Confirmed strategies: html_body
Basis: html_body: payload reached script context; status=200

36. verify-47a4d2c045d6

验证方式: 沙箱 POC 验证

状态: 已验证

证据摘录: {"verified": true, "status": "confirmed", "request_url": "http://host.docker.internal:8765/vul/sqli/sqli_search.php?submit=%E6%90%9C%E7%B4%A2&name=1%27", "baseline_url": "http://host.docker.internal:8765/vul/sqli/sqli_search.php?submit=%E6%

37. verify-c0b100b98d7b

验证方式: 沙箱 POC 验证

状态: 已验证

证据摘录: {"verified": true, "status": "confirmed", "request_url": "http://host.docker.internal:8765/vul/sqli/sqli_del.php?id=1%27", "baseline_url": "http://host.docker.internal:8765/vul/sqli/sqli_del.php?id=1", "observed_status": 200, "baseline_stat

38. verify-ddba5bd21a7a

验证方式: 沙箱 POC 验证

状态: 已验证

证据摘录: {"verified": true, "status": "confirmed", "request_url": "http://host.docker.internal:8765/vul/sqli/sqli_del.php?id=1%27", "baseline_url": "http://host.docker.internal:8765/vul/sqli/sqli_del.php?id=1", "observed_status": 200, "baseline_stat

39. verify-00ce3dd94b7b

验证方式: internal_content_reflection

状态: 已验证

证据摘录: Page: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php
Method: GET
Parameter: url
Baseline URL: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.php?url=http://127.0.0.1/vul/ssrf/ssrf_info/info1.php
Probe URL: http://127.0.0.1:8765/vul/ssrf/ssrf_curl.p

40. verify-389e476aa8f1

验证方式: internal_content_reflection

状态: 已验证

证据摘录: Page: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php
Method: GET
Parameter: file
Baseline URL: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.php?file=http://127.0.0.1/vul/ssrf/ssrf_info/info2.php
Probe URL: http://127.0.0.1:8765/vul/ssrf/ssrf_fg.ph

41. verify-bb6d4fe80f0e

验证方式: 静态 JS 敏感信息验证

状态: 已验证

证据摘录: rule_id=plaintext-password; line=704; match_count=1;
sample=masked(plaintext-password:len=2;sample=**); remediation=Remove browser-shipped secrets;
use server-issued short-lived tokens and rotate leaked material.

42. verify-d44f4c39848b

验证方式：静态 JS 敏感信息验证

状态：已验证

证据摘录：rule_id=plaintext-password; line=679; match_count=1;
sample=masked(plaintext-password:len=2;sample=**); remediation=Remove browser-shipped secrets;
use server-issued short-lived tokens and rotate leaked material.

附录 C：待验证线索

1. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Sources=localStorage; DOM sinks=innerHTML; DOM sink evidence=c.innerHTML@L1:C2899 `c.innerHTML=b` | c.innerHTML@L1:C2899 `c.innerHTML=b`; remediation=Replace innerHTML/outerHTML/document.write with textContent or DOM-safe rendering helpers.

后续建议：

- 将该 JS 上下文作为后续清单使用。

2. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Sources=location.hash, location.href; DOM sinks=innerHTML, outerHTML; DOM sink evidence=innerHTML@L2:C9981 `o.appendChild(a).innerHTML="<a id="+u+" "></a><select id="+u+"-\fj' msallowcapture=""><option selected=""></option></select>"` | a.innerHTML@L2:C22157 `a.innerHTML="<a href='#"></a>"` | a.innerHTML@L2:C22376 `a.innerHTML="<input/>"; remediation=Replace innerHTML/outerHTML/document.write with textContent or DOM-safe rendering helpers.

后续建议：

- 将该 JS 上下文作为后续清单使用。

3. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Sources=location.hash, location.href; DOM sinks=innerHTML; DOM sink evidence=innerHTML@L2:C9731 `o.appendChild(a).innerHTML="<a id="+u+" "></a><select id="+u+"-\fj' msallowcapture=""><option selected=""></option></select>"` | a.innerHTML@L2:C21907 `a.innerHTML="<a href='#"></a>"` | a.innerHTML@L2:C22126 `a.innerHTML="<input/>"; remediation=Replace innerHTML/outerHTML/document.write with textContent or DOM-safe rendering helpers.

后续建议：

- 将该 JS 上下文作为后续清单使用。

4. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Execution sinks=function; ast.eval_calls=0; ast.new_function_calls=0; remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

后续建议：

- 将该 JS 上下文作为后续清单使用。

5. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Execution sinks=function, setInterval, setTimeout; ast.eval_calls=0; ast.new_function_calls=0; remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

后续建议：

- 将该 JS 上下文作为后续清单使用。

6. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Execution sinks=function; ast.eval_calls=0; ast.new_function_calls=0; remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

后续建议：

- 将该 JS 上下文作为后续清单使用。

7. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Execution sinks=Function, function; ast.eval_calls=0; ast.new_function_calls=0;
remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

后续建议：

- 将该 JS 上下文作为后续清单使用。

8. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Execution sinks=function, setTimeout; ast.eval_calls=0; ast.new_function_calls=0;
remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

后续建议：

- 将该 JS 上下文作为后续清单使用。

9. JavaScript 辅助评估

判断依据：静态 JS 发现仅保留为辅助上下文。

证据摘要：Execution sinks=function, setTimeout; ast.eval_calls=0; ast.new_function_calls=0;
remediation=Replace eval/new Function/string timers with explicit function dispatch or safe parser logic.

后续建议：

- 将该 JS 上下文作为后续清单使用。

附录 D：原始执行指标

```
{
  "execution_summary": {
    "completed_steps": 14,
    "total_steps": 14,
    "completed_subagents": 1,
    "total_subagents": 3,
    "step_decision_count": 62,
    "subagent_decision_count": 0,
    "step_llm_fallback_count": 43,
    "subagent_llm_fallback_count": 0,
    "verified_finding_count": 39,
    "verification_record_count": 42,
    "verification_methods": [
      "authenticated_idor_object_access",
      "authenticated_privileged_route_replay",
      "backup_passive_exposure",
      "boolean_differential",
      "bounded_login_submission",
      "browser_dom_execution_context",
      "browser_href_context",
      "browser_script_context",
      "docker_poc",
      "internal_content_reflection",
      "static_js_secret_exposure"
    ],
    "verification_sources": [
      "browser_capture",
      "docker_poc",
      "internal_content_reflection",
      "response_diff",
      "static_secret_exposure",
      "structured_proof"
    ],
    "unverified_lead_count": 9,
    "artifact_count": 9
  },
  "benchmark_summary": {
    "manifest_name": "llm_vulnerability_loop_benchmark",
    "manifest_version": "v2.0",
    "passed_count": 1,
    "total_count": 5,
    "all_passed": false,
    "passed_categories": [
      "ssrf"
    ],
    "failed_categories": [
      "sql",
      "xss",
      "auth",
      "backup_js_config"
    ],
    "category_scores": {
      "sql": 0.83,
      "xss": 0.83,
      "auth": 0.67,
      "ssrf": 1.0,
      "backup_js_config": 0.83
    }
  },
  "coverage_metrics": {
    "manifest_name": "llm_vulnerability_loop_benchmark",
    "manifest_version": "v2.0",
    "steps": {
      "total": 14,
      "completed": 14,
      "blocked": 0,

```

```

"failed": 0,
"by_name": {
"state_bootstrap": "completed",
"recon": "completed",
"backup_audit_extended": "completed",
"config_audit": "completed",
"sql_scan": "completed",
"sql_bypass": "completed",
"js_audit": "completed",
"xss_triage": "completed",
"ssrf_triage": "completed",
"permission_bypass": "completed",
"cors_audit": "completed",
"weak_password": "completed",
"jwt_audit": "completed",
"poc_verify": "completed"
}
},
"subagents": {
"total": 3,
"completed": 1,
"blocked": 0,
"failed": 0,
"by_name": {
"backup-source-audit-child": "completed",
"js-derived-api-child": "running",
"xss-multi-entry-child": "running"
},
"contributions": [
{
"subagent_id": "subagent-a453200bb9b1",
"task_name": "backup-source-audit-child",
"status": "completed",
"done_reason": "backup_artifact_without_sensitive_proof",
"seed_step_id": "step-a589a50c6f2c",
"verified_finding_ids": [],
"output_context": {
"task_name": "backup-source-audit-child",
"iterations": 4,
"tool_calls": 4,
"decision_count": 0,
"llm_fallback_count": 0,
"done_reason": "backup_artifact_without_sensitive_proof",
"lead_ids": [
"lead-ca95b833d4ea"
],
"verification_ids": [],
"verified_finding_ids": [],
"artifact_ids": [
"art-backup-source-audit-child-config-preview-408804"
],
"route_candidates": [
"http://127.0.0.1:8765/.git/config"
],
"endpoint_seeds": [
"http://127.0.0.1:8765/.git/config"
],
"recommended_next_tests": [
{
"type": "source_route_followup",
"priority": "high",
"target": "http://127.0.0.1:8765/.git/config",
"reason": "Backup child recovered accessible configuration/source artifact."
}
]
}
],
},

```



```

{
  "subagent_id": "subagent-79f3281f6144",
  "task_name": "js-derived-api-child",
  "status": "running",
  "done_reason": "",
  "seed_step_id": "step-af32c082fb97",
  "verified_finding_ids": [],
  "output_context": {}
},
{
  "subagent_id": "subagent-4b6131dd1a9d",
  "task_name": "xss-multi-entry-child",
  "status": "running",
  "done_reason": "",
  "seed_step_id": "step-0a264589b7ad",
  "verified_finding_ids": [],
  "output_context": {}
}
],
"tools": {
  "seen": [
    "artifact_capture",
    "backup_audit_bridge",
    "browser_action",
    "build_ssrf_probe_set",
    "compare_http_responses",
    "cors_audit_bridge",
    "create_callback_endpoint",
    "discover_sql_candidates",
    "extract_dom_sinks",
    "extract_fetch_calls",
    "extract_forms_from_html",
    "extract_js_endpoints",
    "extract_links_from_html",
    "extract_parameters_from_response",
    "fetch_candidate_file",
    "generate_poc_verification_case",
    "generate_sql_bypass_plan",
    "grep_sensitive_patterns",
    "http_request",
    "js_audit_bridge",
    "jwt_audit_bridge",
    "parse_config",
    "parse_js_ast",
    "parser_confusion_probe",
    "permission_bypass_bridge",
    "poll_callback_events",
    "probe_sql_boolean",
    "recon_bridge",
    "replay_request_with_mutation",
    "run_poc_in_docker",
    "run_skill_deep_scan",
    "run_sql_bypass_probe",
    "run_waf_bypass_strategy",
    "same_request_different_session_replay",
    "session_store",
    "ssrf_triage_bridge",
    "state_bootstrap_bridge",
    "weak_password_bridge",
    "xss_triage_bridge"
  ],
  "step_observation_count": 62,
  "subagent_observation_count": 4
},
"findings": {
  "verified_count": 42,

```

```
"categories": [
  "authorization",
  "backup_source_audit",
  "frontend_secret_exposure",
  "sql_injection",
  "ssrf",
  "weak_password",
  "xss"
],
"verification": {
  "methods": [
    "authenticated_idor_object_access",
    "authenticated_privileged_route_replay",
    "backup_passive_exposure",
    "boolean_differential",
    "bounded_login_submission",
    "browser_dom_execution_context",
    "browser_href_context",
    "browser_script_context",
    "docker_poc",
    "internal_content_reflection",
    "static_js_secret_exposure",
    "strategy_assessment"
  ],
  "gaps": [],
  "fallbacks": {
    "total": 0
  },
  "benchmarks": [
    {
      "name": "sql",
      "step_status": {
        "sql_scan": "completed",
        "sql_bypass": "completed",
        "poc_verify": "completed"
      },
      "child_status": {},
      "tool_seen": {
        "discover_sql_candidates": true,
        "probe_sql_boolean": true,
        "generate_sql_bypass_plan": true,
        "run_sql_bypass_probe": true,
        "run_poc_in_docker": true
      },
      "finding_seen": {
        "sql_injection": true
      },
      "fallback_count": 0,
      "round_count": 17,
      "max_fallbacks": 8,
      "max_rounds": 14,
      "score": 0.83,
      "passed": false
    },
    {
      "name": "xss",
      "step_status": {
        "js_audit": "completed",
        "xss_triage": "completed"
      },
      "child_status": {
        "xss-multi-entry-child": "running"
      },
      "tool_seen": {
        "extract_dom_sinks": true,
```

```
"replay_request_with_mutation": true,
"browser_action": true
},
"finding_seen": {
  "xss": true,
  "xss_child_audit": false
},
"fallback_count": 10,
"round_count": 10,
"max_fallbacks": 14,
"max_rounds": 14,
"score": 0.83,
"passed": false
},
{
  "name": "auth",
  "step_status": {
    "permission_bypass": "completed"
  },
  "child_status": {
    "auth-differential-child": "missing"
  },
  "tool_seen": {
    "create_identity": false,
    "session_store": true,
    "same_request_different_session_replay": true,
    "compare_http_responses": true
  },
  "finding_seen": {
    "authorization": true,
    "authorization_child_audit": false
  },
  "fallback_count": 7,
  "round_count": 7,
  "max_fallbacks": 16,
  "max_rounds": 16,
  "score": 0.67,
  "passed": false
},
{
  "name": "ssrf",
  "step_status": {
    "ssrf_triage": "completed"
  },
  "child_status": {},
  "tool_seen": {
    "create_callback_endpoint": true,
    "build_ssrf_probe_set": true,
    "poll_callback_events": true,
    "parser_confusion_probe": true
  },
  "finding_seen": {
    "ssrf": true
  },
  "fallback_count": 6,
  "round_count": 6,
  "max_fallbacks": 6,
  "max_rounds": 8,
  "score": 1.0,
  "passed": true
},
{
  "name": "backup_js_config",
  "step_status": {
    "backup_audit_extended": "completed",
    "config_audit": "completed",
    "js_audit": "completed"
  }
}
```

```
,
"child_status": {
  "backup-source-audit-child": "completed",
  "js-derived-api-child": "running"
},
"tool_seen": {
  "fetch_candidate_file": true,
  "parse_config": true,
  "grep_sensitive_patterns": true,
  "extract_js_endpoints": true,
  "extract_fetch_calls": true
},
"finding_seen": {
  "backup_source_audit": true,
  "js_derived_api": false
},
"fallback_count": 13,
"round_count": 17,
"max_fallbacks": 15,
"max_rounds": 18,
"score": 0.83,
"passed": false
}
}
}
```